

We Are Still Fighting Yesterday's Attack Paths: While Identity and Endpoint Exposures Drive Today's Cyber Incidents

The Cost of Protecting Where Attackers Were Instead of Where They Are Now

By Godfrey Kutumela, CEO and Lead Cybersecurity Practitioner, Nucleus Systems — May 2026
Identity Governance | Endpoint Visibility | Attack Path Analysis | Security Program Alignment

There is a pattern in cybersecurity that no amount of technology alone will fix. Attackers move. We watch. They pivot. We document. They exploit the gap between where our controls were built and where they now operate. And by the time our governance structures authorize the shift, the damage is already done.

This is not a failure of effort. Security teams work hard, compliance programmes are extensive, and, in most organizations, the controls in place are genuinely well managed. The problem is not the quality of what we protect. It is the direction we are looking when we protect it. Too many security programmes remain anchored to the threat models of previous years, funded around the incidents that hurt most in the past, and governed by benchmarks built when the attack surface looked nothing like it does today.

Attackers, by contrast, are not sentimental. They follow the path of least resistance, and they follow it continuously. They have been watching our protection strategies for years. They know that our endpoint detection was built for managed Windows devices, not for browsers, SaaS sessions, and edge appliances. They know that our identity controls were hardened for on-premises Active Directory, not for the hybrid, multi-cloud, token-rich environment that every enterprise now operates in. They know that our patching cadences were designed around quarterly cycles, not around the 32-day median exposure window that internet-facing vulnerabilities now carry.

They know these things because the data confirms them. And they have chained themselves to nothing from the past. But we have.

“Attackers follow the path of least resistance, and they follow it continuously. They know where your controls were built. And they know where they were not.”

This article makes a direct argument. The two most important cyber incident attack paths today are identity compromise and compromise of endpoints and exposed infrastructure. These are not new categories. What is new is the extent to which modern incidents use them in combination, the speed at which they are exploited, and the widening gap between where these threats operate and where most security programmes remain focused.

That gap is not accidental. It is the predictable result of governance structures that protect yesterday's attack surface with yesterday's funding priorities, and benchmark security maturity against controls designed for threats that the most capable adversaries moved on from years ago.

I. The Chained Benchmark Problem: Why We Protect Where We Were

Every security programme inherits its shape from the incidents that preceded it. The controls that organizations invest most heavily in today reflect, to a significant degree, the incidents that hurt most five or ten years ago. This is not irrational. Learning from past losses is how mature systems improve. The problem arises when the inheritance calcifies, when the benchmark becomes the ceiling rather than the floor, and when the funding and governance structures lock in yesterday's threat model as the permanent frame of reference.

This is the chained benchmark problem. It shows up in how security budgets are justified, how control frameworks are applied, how maturity is measured, and how the board is told the organization is secure. It shows up in language such as “we are compliant with ISO 27001,” “we have implemented the CIS Top 18,” or “our penetration test came back clean.” None of these statements is wrong. Each of them may also be entirely insufficient for the threat environment in which the organization actually operates.

“Compliance tells you whether your controls meet a benchmark. It does not tell you whether that benchmark was built for the adversary you are actually facing.”

The chained benchmark problem has a specific operational mechanism. As the threat landscape shifts, the controls in which organizations are most heavily invested, both financially and institutionally, create inertia. Changing them requires budget reallocation, which requires a business case, which requires an incident that demonstrates the gap, which requires having already suffered the loss that the new control would have prevented. The attack cycle is self-reinforcing and self-replicating. The organization learns from the incident, funds the fix, anchors the new benchmark, and the adversary moves on to exploit the next available gap, creating a vicious circle.

In today's tech stack, endpoint exposure extends beyond managed laptops and desktops to include **browsers, mobile Apps, SaaS sessions, VPNs, edge appliances, unmanaged devices (often misclassified as bring-your-own-devices), cloud workloads, and legacy systems**. Therefore, managed endpoints are targeted as conduits to exploit what lies behind them, including browsers, SaaS sessions, VPNs, and edge appliances; traditional endpoint detection does not fully address these threats. From public exploits to zero-days, organizations have an average of 32 days to patch and often do not.

The result is a persistent asymmetry not in technological capability but in agility. And it is an asymmetry that would be effectively addressed through architectural governance that places identity and endpoints at the epicentre of a new control framework directly linked to today's adversaries.

The Lag in Numbers

The data makes the lag concrete. Mandiant's M-Trends data has tracked the most common initial infection vectors every year for a decade. The story it tells is not of sudden change. It is of gradual, sustained shifts that security programme funding and governance have consistently been slow to follow.

Evidence	Data Point
Vulnerability exploitation as initial infection vector, Mandiant 2021	37% of incidents
Vulnerability exploitation as initial infection vector, Mandiant 2025	32% of incidents, #1 for 6 consecutive years

Stolen credentials as initial vector, Mandiant 2023	10% (rising trend)
Stolen credentials as initial vector, Mandiant 2024	16% (overtook email phishing)
Voice phishing rise, Mandiant 2025	Up to 11%; email phishing fell to 6%
Identity weaknesses present in Unit 42 investigations, 2026	Nearly 90% of cases
Identity-based techniques as an initial access driver, Unit 42 2026	65% of initial access
Intrusions spanning multiple attack surfaces, Unit 42 2026	87% of all intrusions
Browser-based activity involved in intrusions, Unit 42 2026	48% of all intrusions
Malware-free detections, CrowdStrike 2026	82% of all detections
Edge device and VPN exploitation increase, Verizon 2025 DBIR	From 3% to 22% of exploitation targets
Median patch time for internet-facing vulnerabilities, Verizon 2025	32 days
MFA effectiveness against credential-based compromise, Microsoft 2025	Blocks over 99% of attacks when deployed
Identity attacks, such as password spray, Microsoft 2025	97% of identity attacks

These numbers describe a clear and sustained directional shift. The adversary's preferred entry points have migrated from perimeter vulnerabilities toward identity, and within endpoint attacks, from malware toward living-off-the-land techniques that leverage legitimate tools, valid credentials, and trusted sessions. The **22% edge device and VPN exploitation** figure from Verizon 2025, up from **3%** the prior year, is not a rounding error. It is a sevenfold increase in a single measurement period. Security programme funding and governance have not moved at anywhere near that speed.

II. Identity: The Door That Has Been Unlocked for Years

Identity is not a new attack vector. Credential theft, phishing, and password abuse have appeared in incident data for years. What has changed is the scale, sophistication, and the extent to which identity has become the primary attack path rather than one threat among many.

Notable structural shifts explain this:

- First, cloud and SaaS have made identity the new boundary for access. Credentials, tokens, and session state now determine access more than the traditional network perimeter. An attacker with valid credentials can often reach the same systems as a legitimate user from anywhere in the world.
- Second, the supply of compromised credentials has become an advantage for attackers. Microsoft's 2025 Digital Defense Report found that 85% of usernames targeted in password spray attacks appeared in known credential leaks, while 97% of identity attacks used password spray techniques rather than brute force. This matters because attackers are not guessing wildly; they are using leaked identity data carefully, spreading attempts across many accounts, staying below lockout thresholds, and blending into normal authentication noise.

The implication is clear: identity risk is no longer just about stolen passwords. It is about stale accounts, weak MFA coverage, excessive privilege, exposed tokens, and authentication activity that looks legitimate until it is too late. Identity has become the attacker's quietest path into the enterprise.

"Attackers do not need to hack in when they can log in. And in most organizations, the conditions that allow them to log in with stolen credentials have existed for years without triggering formal governance action."

The Unit 42 2026 Global Incident Response Report makes the current state of identity exploitation explicit. Identity weaknesses played a material role in nearly 90% of investigations. Identity-based techniques accounted for 65% of initial access across the entire caseload. These are not tail-risk scenarios. They are the primary attack path. And yet, in most organizations, identity governance remains a programme that is managed at the operational level, reviewed periodically, and escalated to executive and board attention only when a specific incident forces it.

What Identity Governance Actually Means in Practice

The gap between having an identity governance programme and having one that materially reduces incident risk is significant, and it is worth being specific about where the most common failures occur.

- **Orphaned and stale accounts:** accounts belonging to employees who have left the organization, contractors whose access was never deprovisioned, and service accounts that were created for a specific project and never removed, are among the most reliably exploited identity vulnerabilities. They have no active owner who might notice anomalous usage; they often retain permissions granted at the peak of their activity; and they appear in credential leaks at the same rate as active accounts. An identity governance programme that does not address orphaned accounts on a defined, enforceable cadence is not materially reducing identity risk.
- **Excessive privilege access permissions:** The principle of least privilege is one of the most cited security standards and one of the most consistently violated in practice. Administrative accounts with permissions far beyond what their roles require, service accounts with domain-level access when application-level access would suffice, and user accounts that accumulate

permissions through role changes without corresponding revocations are all standard findings in incident post-mortems. The Mandiant finding that privilege escalation occurred in the overwhelming majority of lateral movement cases is no coincidence. Excessive privilege access permissions are the fuel that lateral movement burns.

- **MFA coverage gaps:** Microsoft's finding that MFA blocks unauthorized access with compromised credentials in over 99% of cases when properly deployed should be among the most frequently cited statistics in any board-level security discussion. The operative phrase is "properly deployed." Partial MFA deployment, coverage gaps in legacy systems, MFA bypass techniques such as push fatigue and session hijacking, and the failure to enforce phishing-resistant MFA for privileged accounts are all conditions that enable credential abuse in organizations that believe they have solved the MFA problem. Most have not.
- **Joiner-mover-leaver processes:** the failure to consistently and promptly execute identity lifecycle management, provisioning access when someone joins, adjusting it when they move to a different role, and deprovisioning it when they leave, is one of the most process-visible and process-neglected areas of identity governance. It is also one of the most directly exploitable. An ex-employee with active credentials is not a hypothetical risk. They are an active account that an attacker who has obtained those credentials can use immediately, with no additional escalation required.

Attackers exploit trusted access precisely because **it allows them to enter, move laterally, escalate privileges, and reach critical systems without appearing as outsiders**. When orphaned accounts, excessive permissions, weak MFA coverage, or poor joiner-mover-leaver processes remain unresolved, they are not minor access issues; they become direct pathways to ransomware, data theft, systems disruption, regulatory exposure, and board-level accountability.

That is why Identity Governance must be treated as a governance control, not an access-management procedure. It forces identity exposure to be reviewed on a defined cadence, with high-risk exceptions escalated, owned, and recorded as business risks. The value is that identity risk stops hiding in technical backlogs and becomes visible where business decisions are made. **This matters because identity exposure is never static.** Accounts change, privileges accumulate, users move, contractors leave, and exceptions age quietly. Without continuous governance, trusted access becomes the attacker's most reliable path into the enterprise.

Did We Forget Zero Trust (ZT)? No - We Are Avoiding Problem Dilution

Readers may ask where **Zero Trust** fits into this argument. The answer is simple: Zero Trust has value, but it fails when organizations adopt the language before fixing the identity foundations that make it real. You cannot "never trust, always verify" while orphaned accounts remain active, privileged access is excessive, MFA coverage is incomplete, and joiner-mover-leaver processes are unreliable.

Avoid the conceptual noise trap: sounding modern while leaving the basic IAM conditions that attackers exploit every day in place. The priority is not to brand the programme as Zero Trust; it is to reduce the attack path through clean accounts, enforced MFA, least privilege, monitored privilege escalation, and timely deprovisioning.

Therefore, Effective Identity Governance is the foundation of any credible zero-trust model. Without disciplined identity governance, Zero Trust remains a design ambition. With it, the organization begins to close the trusted access paths ransomware operators rely on most. Zero Trust is not a shortcut around IAM; without identity hygiene and trusted access control, it becomes theatre.

III. Endpoint and Exposure: The Surface That Grew Faster Than Our Defenses

The term "endpoint" is now too narrow. It once meant the managed corporate laptop or desktop protected by an agent, monitored through a console, and defended against malicious files or processes. That model still matters, but it no longer reflects the surface attackers actually exploit.

Today's attack surface includes managed and unmanaged devices, browsers, SaaS sessions, VPNs, edge appliances, firewalls, cloud workloads, virtual infrastructure, web applications, and any exposed system that provides a path to organizational resources. That is why the better framing is endpoint and exposure: endpoint security protects the device; exposure management governs the full surface attackers can reach.

"Endpoint security was built for the managed Windows device. The adversary moved to the browser, the VPN, the SaaS session, and the edge appliance. Most security programmes have not moved with them."

Verizon's 2025 DBIR data makes the shift visible: edge devices and VPNs rose from 3% to 22% of vulnerability targets in a year. This shows attackers moving toward systems that are poorly inventoried, weakly patched, lightly monitored, and rarely covered by traditional endpoint detection.

CrowdStrike's finding that 82% of detections were malware-free reinforces the same point. Attackers increasingly use valid credentials, legitimate tools, remote access pathways, and normal administrative traffic. The issue is not that endpoint tools are useless; rather, many are still optimized to detect malware, while attackers exploit trust, exposure, and visibility gaps.

The Unmanaged Device Problem

Unit 42's finding that **87% of intrusions cross multiple attack surfaces** confirms the modern attack path: attackers do not remain in a single layer. They move from exposed edge devices to compromised sessions, legitimate admin tools, cloud services, and data staging, often faster than visibility can follow.

Unmanaged devices widen that gap. Personal devices, laptops, IoT systems, cloud workloads without agents, and legacy systems all create hidden entry points that lead to movement paths.

The browser now sits at the centre of this exposure. SaaS, email, cloud consoles, collaboration tools, and internal applications all run through it, while credential theft, session hijacking, and malicious extensions often sit beyond traditional EDR visibility. When **48% of intrusions involve browser-based activity**, browser visibility is no longer optional.

WHAT ENDPOINT AND EXPOSURE ACTUALLY COVERS IN 2026

- Managed corporate laptops and desktops (traditional endpoint, generally well-covered)
- Servers and virtual infrastructure (often covered, with gaps in cloud-native workloads)
- Browsers and SaaS sessions (frequently uncovered by traditional EDR)
- VPN concentrators and remote access infrastructure (edge exposure, rapidly growing target)
- Firewalls, routers, and network edge appliances (OT/IT convergence, often unmanaged)
- Unmanaged personal devices accessing organizational resources (BYOD, contractor devices)
- Cloud workloads and containers (covered by CSPM/CWPP where deployed, often not)
- IoT and operational technology devices (connectivity without traditional security agents)
- Legacy systems running outdated operating systems or firmware (cannot support modern agents)

"Greater deficiencies here make what the organization cannot see available for attackers to exploit, and what leadership does not govern becomes their path of least resistance."

IV. How the Attack Path Actually Works: Identity Into Exposure Into Impact

The reason identity, endpoint, and exposure must be treated as linked priorities rather than as separate silos is that modern incidents almost always involve all three. The attack path does not begin with a vulnerability and end with a credential. It begins wherever the path of least resistance leads, and it moves fluidly between attack surfaces until it reaches its objective.

The typical modern incident path looks approximately like this. A user is phished, vished, or has their credentials harvested from a credential leak. The attacker uses those credentials to authenticate to a VPN, a SaaS application, or a cloud management console. From that position, they move laterally through the environment using legitimate tools, escalating privileges using the over-permissioned accounts or orphaned service accounts they encounter along the way. They reach the data, infrastructure, or operational systems that represent their objective. They complete their mission, whether that is data exfiltration, ransomware deployment, or persistent access installation, and they do so, in many cases, without triggering any of the controls that the organization's security programme was built around.

"The attack path does not follow your org chart. It follows your access paths. And your access paths extend further and are less controlled than most security programmes acknowledge."

Unit 42's 2026 data makes the multi-surface nature of this path concrete. Eighty-seven percent of intrusions involved activity across multiple attack surfaces, including endpoints, networks, cloud infrastructure, SaaS applications, and identity. This is not a minority pattern. It is the dominant pattern. And it means that a security programme that is excellent in one domain but has significant gaps in another is not providing the coverage that the incident data says is required.

The CrowdStrike 2026 finding that the fastest eCrime breakout time, the time between initial access and lateral movement, was recorded at 27 seconds, adds urgency to this picture. The window between initial compromise and lateral movement has collapsed to near-zero in the most aggressive attack scenarios. The implication for detection and response is significant: a security programme that relies on detecting the second stage of an attack, lateral movement, privilege escalation, or data staging, rather than the first stage, initial access, is operating with a margin that in the fastest scenarios does not exist.

The Convergence Point: Where Identity and Exposure Meet

The convergence of identity and endpoint exposure as attack paths is not merely statistical. It is architectural. Modern enterprise environments have created conditions in which identity serves as the access control mechanism for infrastructure exposed across a vast, partially invisible surface. An attacker who compromises an identity need not compromise a device in the traditional sense. They are operating inside the security perimeter as a trusted principal.

This is why the traditional attack lifecycle model, which sequences perimeter breach, internal reconnaissance, lateral movement, and objective execution as distinct phases, increasingly fails to describe modern incidents. In many current attacks, the perimeter breach and the internal access are the same event. Logging in to a SaaS application with compromised credentials is both initial access and a foothold within the organization's data environment. There is no separate lateral movement phase if the initial access point already carries sufficient privilege to reach the objective directly.

The governance response must match this architectural reality. Identity and endpoint exposure are not the same problem. They are two facets of the same problem: the failure to govern access to organizational resources across the full scope of surfaces through which that access occurs.

V. Policy Alignment: Where Governance Meets the Attack Path

There is now an urgent need for a radical policy shift in how organizations govern cyber risk. NIST, ISO, CIS, and other frameworks remain useful baselines, but they cannot be treated as static playbooks for today's incident reality. Attackers are not stopped by evidence that a policy exists; they are stopped when governance forces protection where attacks are actually happening. The shift required is from compliance fulfilment to **evidence of attack-path accountability**.

Today's priority governance focus must therefore move to the surfaces most consistently exploited in modern incidents:

- **Identity systems**
- **Privileged access**
- **Unmanaged endpoints**
- **Exposed infrastructure**
- **Browsers and SaaS sessions**
- **VPNs and edge devices**

This is where policy must become operationally meaningful. A policy that exists but does not force review, measurement, escalation, remediation, or formal risk acceptance does not govern the attack path. It is documenting intent. The governance test is whether the organization can prove that its highest-risk identity and endpoint exposures are known, owned, tracked, and either remediated or consciously accepted as business risk.

That means **Policy 1: Identity Governance** and **Policy 2: Endpoint Visibility** must become leadership-visible controls rather than back-office documentation. They should be reviewed with the same seriousness as financial, legal, and operational risk because they govern the two pathways most likely to turn a technical weakness into a business crisis.

In a ransomware incident, the board should not only ask, “**How did this happen?**” It should ask:

- Were there known policy gaps?
- Were there implementation gaps?
- Were exceptions accepted without closure?
- Were identity risks unresolved?
- Were endpoint or browser visibility blind spots present?
- Did exposed systems allow the incident to progress?
- Were these risks visible to leadership before the incident?
- If they were visible, who owned the decision to carry them?

These questions change the nature of cyber governance. They move the discussion from blame after failure to accountability before impact. If identity gaps, excessive privileges, unmanaged devices,

browser blind spots, or exposed infrastructure were known but not escalated, the issue is not only technical. It is a governance failure.

The purpose of Policies 1 and 2 is to prevent that failure. They create the mechanism to identify the organization's most exploited attack paths, force ownership of unresolved gaps, and ensure that leadership understands the business exposure before attackers turn it into a crisis.

“Enforcing such an elevated layer of policy governance will yield a measurable investment return by keeping cyber protection aligned with where attackers are moving and reducing the gap between policy intent and real-world exposure. Its impact is fewer silent weaknesses, faster risk decisions, and clearer board accountability before an incident forces the issue.”

Policy 1: Identity Governance Policy

Privileged access, orphaned accounts, excessive permissions, and joiner-mover-leaver processes must be reviewed on a defined cadence, with unresolved high-risk exceptions formally escalated and recorded as business risks.

Policy 1 gives governance force to a simple reality: **identity is one of the most exploited attack paths in modern cyber incidents, and many of its weaknesses are preventable.** These gaps persist not because organizations are unaware of identity risk, but because identity exposure is often managed operationally instead of governed with the urgency the threat demands.

Policy 1 focuses on the conditions most often found in identity-related incident failures:

- **MFA gaps** that leave users, privileged accounts, or legacy systems exposed
- **Privileged access** that is broader than the role requires
- **Orphaned and stale accounts** with no active owner
- **Excessive permissions** that accumulate through role changes
- **Weak joiner-mover-leaver processes** that fail to adjust or remove access on time

These weaknesses are dangerous because they accumulate quietly. An orphaned account does not announce itself. Excessive privilege does not create obvious log noise. A departing employee's access is not revoked unless a process enforces it. Compromised credentials can remain useful to attackers for long periods when identity hygiene, monitoring, and MFA coverage are weak.

The escalation requirement is what turns Policy 1 from an access-management activity into board-level accountability. When high-risk identity gaps are formally recorded in the enterprise risk register, with owners, remediation dates, and accepted exceptions, the organization has made a conscious decision about risk. Without that visibility, the same risk may still exist, but it is being accepted accidentally and usually discovered only after an incident.

Policy 2: Endpoint Visibility Policy

All endpoints, including legacy and unmanaged devices, must be inventoried, risk-rated, and covered by appropriate detection, protection, or documented compensating controls, with gaps formally accepted as risk if unaddressed.

Policy 2 applies the same governance logic to endpoint and exposure risk: organizations often have devices, workloads, browsers, and edge systems operating outside full security visibility; **the first risk is what the organization cannot see**. Risk-rating turns endpoint visibility from a device-counting exercise into a risk decision. A contractor laptop with access to financial systems, an exposed cloud workload, and an isolated legacy printer do not carry the same exposure; **prioritization must follow business impact, not inventory volume**.

Formal risk acceptance makes unresolved gaps accountable. When executives or the board accept an endpoint visibility gap with a named owner and review date, the gap becomes a conscious business decision rather than a hidden technical weakness; **silence is replaced with ownership**.

Governing the Browser Attack Surface Visibility

The browser should not be treated as a minor application running on the endpoint. It has become a primary enterprise access layer. For governance purposes, it belongs inside the Endpoint Visibility and Exposure domain because it is part of the user execution environment. But operationally, it requires its own control plane: browser hardening, extension governance, SaaS session visibility, credential theft protection, and web-based data loss controls. In modern incidents, the browser is where identity, endpoint, SaaS, and data exposure converge. Policy 2: Endpoint Visibility Policy should include a dedicated sub-domain called: **Browser and Web Session Visibility**, and that sub-domain should cover:

- Browser inventory and version control
- SaaS and web session visibility
- Phishing and credential theft protection
- Corporate vs personal browser profile separation
- Data leakage controls in web and GenAI tools
- Visibility for unmanaged and lightly managed devices

This is where governance either proves its value or exposes its absence. A board that only receives assurance that policies exist is not receiving decision-grade visibility into cyber risk. It needs evidence that policies are implemented, exceptions are known, gaps are owned, remediation is tracked, and unresolved exposure has been formally accepted as business risk.

Otherwise, the organization is not governing cyber risk; it is documenting cyber intent while attackers exploit operational reality. The required shift is therefore clear: *measure governance by evidence of enforcement, not by audit-style reporting of mere policy presence*.

If known identity gaps, endpoint blind spots, unmanaged exposure, or accepted exceptions allowed the incident to progress, the failure is not only technical but also a governance failure. That is why Policies 1: Identity Governance and 2: Endpoint Visibility must be reviewed, measured, escalated, and reported at the executive and board levels.

VI. What Shifting With the Threat Landscape Actually Requires

The call to shift security protection efforts as the threat landscape shifts is, at the operational level, a call to continuous reprioritization. This is easier to state than to operationalize. Security programmes have budgets set annually, governance structures operating on quarterly cycles, and control frameworks certified periodically. The adversary has no budget cycle and no governance committee.

The asymmetry in agility between attacker and defender is, in part, a structural consequence of how organizations make resource allocation decisions. Addressing this asymmetry requires changes at three levels: technical, programme, and governance.

At the Technical Level: Align Controls to Current Attack Paths

The most immediately actionable technical response to the evidence presented in this article is a control coverage audit framed around the two dominant attack paths, not around compliance frameworks or historical benchmarks. The audit questions should be straightforward.

- **For identity:** What percentage of privileged accounts are protected by phishing-resistant MFA? What is the current count of orphaned and stale accounts? What is the average time between an employee's departure and the deprovisioning of their access? What is the current scope of over-permissioned accounts, and what is the remediation backlog? Where do identity-based anomalies generate alerts, and where do they not?
- **For endpoint and exposure:** What is the current device inventory, and what percentage of devices accessing organizational resources are enrolled in endpoint management? What coverage gaps exist in browsers, SaaS, VPN infrastructure, edge appliances, cloud workloads, and unmanaged devices? What is the current patch cadence for internet-facing systems, and what is the exposure window for known critical vulnerabilities? Where does EDR and XDR telemetry have visibility, and where are its blind spots?

These questions do not require a new framework. They require honest answers, architecture-level governance, and a control implementation model explicitly aligned with identity and endpoint/exposure threats. Security architecture must ensure that MFA, privileged access, endpoint telemetry, browser controls, SaaS visibility, patching, and compensating controls are not implemented as isolated technical activities, but as governed design requirements mapped to the attack paths most likely to produce business impact.

The goal is to make coverage gaps visible at the design, implementation, and assurance levels before they become incident findings buried in operational reports.

At the Programme Level: Reprioritize Investment Toward Current Attack Paths

Security programme investment should be periodically realigned to reflect the current threat landscape rather than the threat landscape that shaped the previous budget cycle. This is a specific recommendation, not a general one. The share of **edge devices and VPNs** among exploitation targets increased from **3% to 22%** in a single year, a budget signal. The **65% identity-based** initial access figure signals programme priority. The **82% malware-free detection rate** is a technology investment signal: it means that signature-based detection and prevention controls, while still necessary, are increasingly insufficient as the primary detection mechanism, and that behavioral

analytics, identity threat detection, and exposure management must receive proportionally greater investment.

The practical challenge is that reprioritization often means shifting funding away from controls built for yesterday's attack paths toward controls that reduce today's exposure. That requires a harder board-level conversation: what risk are we carrying, what business outcome is exposed, and which investments now deliver the greatest reduction in ransomware and incident impact?

At the Governance Level: Build the Mechanism That Forces Continuous Realignment

The governance-level response to the chained benchmark problem is the most important and the most durable. Technical controls change as the threat landscape changes. Programme priorities shift with budget cycles. The governance mechanism that forces both to stay aligned with the current threat environment is what prevents the lag from accumulating.

The mechanism has four parts:

- **Board-level threat reviews:** Material shifts such as edge-device exploitation, voice phishing, and faster breakout times should be reviewed as business risk, not buried in operational updates.
- **Attack path risk entries:** Identity compromise and endpoint/exposure risk should be explicit enterprise risk register items, with known gaps, owners, and accepted exceptions recorded.
- **Investment tied to attack paths:** Security budgets should be tested against current incident data: Does this investment reduce the risks attackers are exploiting now?
- **Formal gap closure:** Known gaps under Policies 1 and 2 must be closed or formally accepted with an owner, exposure estimate, and review date, turning silent weaknesses into governed decisions.

Effective governance creates value by shifting cyber risk from a delayed technical reaction to a continuous leadership decision, keeping controls, investment, and accountability aligned with where attackers are moving now.

This may sound like a heavy escalation of technical and operational issues to leadership and the board. But the choice is not between escalation and no escalation; it is between **controlled escalation before an incident** and **forced escalation after one**. If identity gaps, endpoint blind spots, and exposed systems are not governed now, a ransomware event will disrupt all governance affairs anyway through daily crisis meetings, emergency board briefings, legal updates, recovery decisions, and public-impact discussions over the next two to three weeks. Better to make the hard governance decisions while preventive and risk-mitigation options still exist.

VII. Conclusion: Unchaining the Security Programme

The threat landscape moves continuously. It does not wait for governance cycles, budget approvals, or compliance certifications. It follows the path of least resistance, and it has been following that path toward identity and exposed infrastructure long enough that the evidence is now overwhelming and consistent across every major incident data source.

The chained benchmark problem is real, costly, and fundamentally a governance failure rather than a technology failure. Organizations that continue to anchor their security programme's priorities to the threat landscape of three or five years ago are not making a technology decision. They are making a risk governance decision, implicitly, without full visibility into what they are deciding, and without the formal accountability structure that a conscious risk acceptance would create.

The two most important attack paths today are identity compromise and compromise of endpoints and exposed infrastructure. The evidence from Verizon, Mandiant, Unit 42, CrowdStrike, and Microsoft, drawn across multiple years and millions of incidents, converges on this conclusion with a consistency that should inform every security investment discussion and every governance conversation about security programme priorities.

"Identity is where attackers gain trust. Endpoint and exposure are where they gain execution, persistence, lateral movement, and operational impact. A defence strategy that does not prioritize both will miss the way modern incidents actually unfold."

Policies 1 and 2 are the governance expression of this evidence. They do not solve the problem by themselves. No policy does. What they do is create the governance conditions in which the identity governance programme and the endpoint visibility programme are reviewed on a cadence that reflects the pace of threat evolution, in which known gaps are visible and accountable rather than buried in operational reports, and in which the decision to carry a known gap is made consciously and formally rather than accidentally and silently.

The adversary has unchained itself from yesterday's attack surface. The security programme's job is to follow. The governance structure's job is to make the following possible by creating accountability, visibility, and investment agility that the threat landscape demands. That is not a technology problem. It is a governance problem. And governance problems have governance solutions.

The strongest lesson from the data is also the simplest: protect where the attacker is, not where they were. And build the governance structures that force the security programme to keep asking, every quarter, every budget cycle, and every board meeting, whether those two things are still the same.

KEY RECOMMENDATIONS SUMMARY

Governance Actions

- **Elevate identity and endpoint exposure as explicit enterprise risk register entries**, with current control coverage assessment, gap records, formal risk acceptance for unaddressed exposures, and named executive owners.
- **Include threat landscape alignment as a standing board agenda item**, with specific focus on whether current security programme priorities reflect the current attack path evidence, not the evidence from the previous budget cycle.

- **Require attack path-aligned justification for security budget allocations**, connecting each proposed investment to its effect on identity or endpoint and exposure risk reduction using financial impact ranges.
- **Implement Policy 1 (Identity Governance) and Policy 2 (Endpoint Visibility) at full governance maturity**, including defined review cadences, formal escalation of high-risk exceptions, and board-level reporting on both attack surfaces.

Programme Actions

- **Conduct a control coverage audit aligned to current attack paths**, specifically assessing MFA coverage for privileged accounts, orphaned account remediation cadence, edge device and VPN patch status, and browser and SaaS session visibility.
- **Reframe endpoint security scope to cover the full exposure surface**: browsers, SaaS, VPN, and edge infrastructure, unmanaged devices, cloud workloads, and legacy systems, not only managed corporate devices.
- **Increase investment in behavioral and identity threat detection relative to signature-based controls**, reflecting the 82% malware-free detection rate and the dominance of credential-based initial access in current incident data.
- **Set and enforce 32-day maximum patch windows for internet-facing systems**, reflecting the Verizon 2025 median exploitation timeline for known vulnerabilities.

KEY SOURCES AND REFERENCES

- Unit 42 Global Incident Response Report 2026 (Palo Alto Networks)
- CrowdStrike 2026 Global Threat Report
- Verizon Data Breach Investigations Report (DBIR) 2025
- Mandiant M-Trends Report 2025 (Google Cloud)
- Microsoft Digital Defense Report 2025
- IBM Cost of a Data Breach Report 2024
- Godfrey Kutumela: “Reframing Critical Infrastructure Risk in the Age of Cyberwar” (Nucleus Systems, May 2026)

ABOUT THE AUTHOR

Godfrey Kutumela is the CEO and Lead Cybersecurity Practitioner at Nucleus Systems, where he advises organisations on cybersecurity governance, technology risk, digital trust, and operational resilience. His work bridges executive-level risk oversight with practical security execution across financial services, SaaS, digital public infrastructure, and critical infrastructure environments.

This article is the fourth in a series examining cybersecurity governance, risk communication, critical infrastructure security, and the governance structures required to align security programmes with the threat landscape they actually face. It focuses on how leaders can move beyond generic control frameworks toward risk-informed governance models that are measurable, defensible, and responsive to real-world threats...